NovaTech Systems — Security Policy

NovaTech Systems • Internal Knowledge Base Document

Field	Value
Document ID	NT-SEC-001
Version	2.0
Effective date	2026-05-20
Owner department	Information Security
Last updated	2026-05-20
Status	Active

Purpose and scope

Defines identity, access, secrets, data-classification, device, phishing, encryption, VPN, and security-incident requirements.

All names, systems, processes, dates, limits, and examples in this document are fictional and exist only for the NovaTech Systems RAG knowledge-base exercise.

1. Security Policy

Production-access accounts must use MFA. Production credentials must not be stored in source code. Approved secrets-management controls must be used for production secrets.

2. Version History

Version	Effective date	Status	Change summary
1.4	2025-09-01	Historical	Baseline access-control and credential-handling requirements.
2.0	2026-05-20	Active	Strengthened production MFA, secrets-management, device-security, and incident-reporting requirements.

3. Authentication and MFA

- MFA is required for all accounts that have production access.
- Employees must not share passwords, MFA codes, recovery codes, or access tokens.
- Use approved identity systems and follow account-recovery procedures rather than bypassing controls.

4. Access Control

NovaTech follows least privilege. Access should be granted only when needed for an authorized business function and should be removed or changed when the requirement ends.

Access lifecycle

1. Request access with the business reason and required system/role.
2. Obtain the required manager or system-owner approval.
3. Provision the minimum role needed.

4. Review access periodically or when the employee changes role.
5. Remove access promptly when employment or business need ends.

5. Secrets Management

- Production credentials, API keys, tokens, and private keys must not be committed to source repositories.
- Use NovaTech's approved secrets-management system for protected runtime secrets.
- If a secret is exposed, treat it as compromised, report it, and rotate/revoke it according to incident guidance.
- Do not paste secrets into tickets, chat, screenshots, or AI prompts.

6. Data Classification

Class	Examples	Handling
Public	Approved public product information	May be shared externally when authorized.
Internal	Internal procedures and non-public business information	Share only with authorized workforce members.
Confidential	Customer data, sensitive business data, security details	Restrict access to authorized personnel and systems.
Restricted	Credentials, high-impact secrets, highly sensitive security material	Use approved protected systems; minimize access and exposure.

7. Phishing and Social Engineering

Treat unexpected credential requests, urgent payment requests, suspicious attachments, and unusual login prompts as potential phishing. Do not bypass security warnings to complete a task faster. Report suspected phishing through the approved security-reporting channel.

8. Device Security

- Use company-managed devices for company work where required.
- Keep operating systems, browsers, and security software updated.
- Lock the device when unattended.
- Report lost or stolen devices immediately to IT and Security.

9. Encryption and VPN

Sensitive data should use approved encryption mechanisms in transit and at rest. Remote access to protected internal systems should use the approved VPN or other explicitly authorized secure access mechanism.

10. Security Incidents

Potential credential exposure, malware, lost devices, unauthorized access, or suspected data disclosure must be reported promptly. Do not attempt destructive cleanup that could remove evidence unless instructed by Security or Incident Response.

11. Related Documents

- NT-IT-001 — IT Support Guide
- NT-HR-004 — Remote Work Policy
- NT-ENG-001 — Engineering Handbook

- NT-HR-005 — Employee Onboarding Guide
- NT-AI-001 — AI Engineering Handbook